

重构网络空间安全防御模型——SARPPR

方滨兴^{1,2,3}, 贾焰^{2,3}, 李爱平^{4*}, 顾钊铨^{2,3}, 于晗⁴

(1. 广州大学网络空间安全学院, 广州 511363;

2. 哈尔滨工业大学(深圳) 计算机科学与技术学院, 深圳 518055;

3. 鹏城实验室新型网络研究部, 深圳 518000;

4. 国防科技大学计算机学院, 长沙 410073)

摘要: 新型网络安全威胁层出不穷, 建立有效的网络安全防御模型已经成为迫切需求和必然趋势。传统的网络安全防御模型包括 PDR (Protection-Detection-Response)、PDRR (Protection-Detection-Response-Recovery) 和 APPDRR (Assessment-Policy Protection-Detection-Reaction-Restoration) 模型等, 其中经典的 APPDRR 模型通过风险分析、安全策略、系统防护、动态检测、应急响应和灾难恢复 6 个环节来提高网络安全性。随着网络攻防手段的不断发展, APPDRR 模型已经不能满足网络安全防御的现实需求。随着网络安全态势分析、主动防御、拟态防御、盾立方等新兴网络安全防御技术的提出与发展, 亟须对原来的网络空间安全防御模型进行重构和扩充。针对该问题, 对 APPDRR 模型进行了重构, 同时根据防护的实际情况, 首次提出了“护卫模式+自卫模式+迭代模式”的 SARPPR (Sensing-Assessment-Response-Policy-Protection-Restoration) 模型, 以涵盖和指导网络空间安全防御的最新技术, 应对复杂的网络安全威胁。从重要活动安全保障角度出发, 在传统“自卫模式”的基础上, 本模型提出了“护卫模式”和“迭代模式”, 实现了事前预防、事中应对、事后复盘的全生命周期防御。该模型是首个覆盖防御全生命周期的网络空间安全保障模型, 可以应对高隐蔽 APT (Advanced Persistent Threat) 等未知网络安全威胁研判, 以及现有信息系统内生安全能力建设等难题。该模型已应用于第 24 届冬季奥林匹克运动会 (简称北京冬奥会)、杭州第 19 届亚洲运动会 (简称杭州亚运会)、第 31 届世界大学生夏季运动会 (简称成都大运会)、中国 (深圳) 国际文化产业博览交易会 (简称文博会)、中国进出口商品交易会 (简称广交会) 等重大活动的网络安全保障, 实现了零事故, 实践结果验证了模型的有效性。

关键词: APPDRR 模型; SARPPR 模型; 护卫模式; 自卫模式; 迭代模式

中图分类号: TP391 **文献标识码:** A

DOI: 10.20172/j.issn.2097-3136.240101

SARPPR: reconstructing cyberspace security defense model

FANG Binxing^{1,2,3}, JIA Yan^{2,3}, LI Aiping^{4*}, GU Zhaoquan^{2,3}, YU Han⁴

(1. Cyberspace Institute of Advanced Technology, Guangzhou University, Guangzhou 511363, China;

2. School of Computer Science and Technology, Harbin Institute of Technology (Shenzhen), Shenzhen 518055, China;

3. Department of New Networks, Peng Cheng Laboratory, Shenzhen 518000, China;

4. School of Computer Science, National University of Defense Technology, Changsha 410073, China)

Abstract: Faced with the new network security threats, establishing an effective network security defense model has become an urgent need. Traditional network security defense models include PDR (Protection-Detection-Response), PDRR (Protection-Detection-Response-Recovery), and APPDRR (Assessment-Policy Protection-Detection-Reaction-Restoration) models, among which the more classic APPDRR model improves network security through six elements: analysis, policy, protection, detection, response and recovery. With the continuous development of network attack and defense methods, the APPDRR model can no longer satisfy the practical needs

基金项目: 国家重点研发计划 (2022YFB31040103); 国家自然科学基金 (62302507)

引用格式: 方滨兴, 贾焰, 李爱平, 等. 重构网络空间安全防御模型——SARPPR[J]. 网络空间安全科学学报, 2024, 2 (1): 2-12.

Citation Format: FANG B X, JIA Y, LI A P, et al. SARPPR: reconstructing cyberspace security defense model[J]. Journal of Cybersecurity, 2024, 2 (1): 2-12.

of network security defense. With the emergence and development of emerging network security defense technologies such as situation awareness, active defense, mimetic defense and shield cube, there is an urgent need to reconstruct and expand the original cyberspace security defense model. In response to this issue, the APPDRR model was restructured and a SARPPR network security defense model of “guard mode + self-defense mode + iterative mode” was proposed to cover and guide the latest technological development of network security defense and respond to complex network security threats. From the perspective of ensuring the safety of important activities, this model extended the “guard mode” and “iterative mode” on the basis of the traditional “self-defense mode”, and achieved a full lifecycle defense of prevention, response and review analysis. This model was the first cyberspace security assurance model that covered the entire lifecycle defense, capable of addressing unknown network security threats such as highly covert APT (Advanced Persistent Threat), as well as the challenges of building endogenous security capabilities in existing information system. This model has been applied to the network security guarantee of major events such as the Beijing Winter Olympics Games, 2022 Hangzhou Asian Games, Chengdu Universiade, Cultural Expo and Canton Fair, achieving zero accidents and verifying the effectiveness of this model.

Keywords: APPDRR model; SARPPR model; guard mode; self-defense mode; iterative mode

0 引言

随着互联网的普及和发展,网络安全问题日益突出。不断增加的网络攻击事件给个人隐私、企业数据和国家安全带来了严重威胁。例如,黑客攻击、勒索软件、恶意软件及各类网络诈骗等安全威胁不断涌现,严重危害了个人隐私和企业数据安全,也给国家的经济和社会稳定带来了严峻挑战。在此背景下,建立有效的网络安全防御模型已成为保障网络空间安全的必要手段,也是促进互联网健康发展的重要保障。网络安全防御模型通过对各种安全威胁进行全面分析和防御,能够有效提高网络的安全性和稳定性,从而保障个人、企业和国家的利益。

近年来,网络安全防御领域发展迅速,已经构建形成了众多网络安全防御模型,包括 PDR (Protec-

tion-Detection-Response) 模型^[1]、PDRR (Protection-Detection-Response-Recovery) 模型^[2]、IPDRR (Identify-Protect-Detect-Respond-Recover) 模型^[3]以及 APPDRR (Assessment-Policy-Protection-Detection-Reaction-Restoration) 模型^[4]等,上述模型不仅通过安全策略、系统防护、灾难恢复等措施来应对安全威胁,同时还能够提高防护组织的安全意识和应对能力,减少安全事件的发生和对系统的影响。其中,APPDRR 模型是目前最有影响力的网络安全防御模型之一。APPDRR 模型包括 6 个要素:风险分析 (Assessment)、安全策略 (Policy)、系统防护 (Protection)、动态检测 (Detection)、应急响应 (Response) 和灾难恢复 (Restoration),如图 1 所示。它强调网络安全的相对性和动态螺旋上升过程,通过不断的风险评估和安全策略调整能够实现网络安全的持续

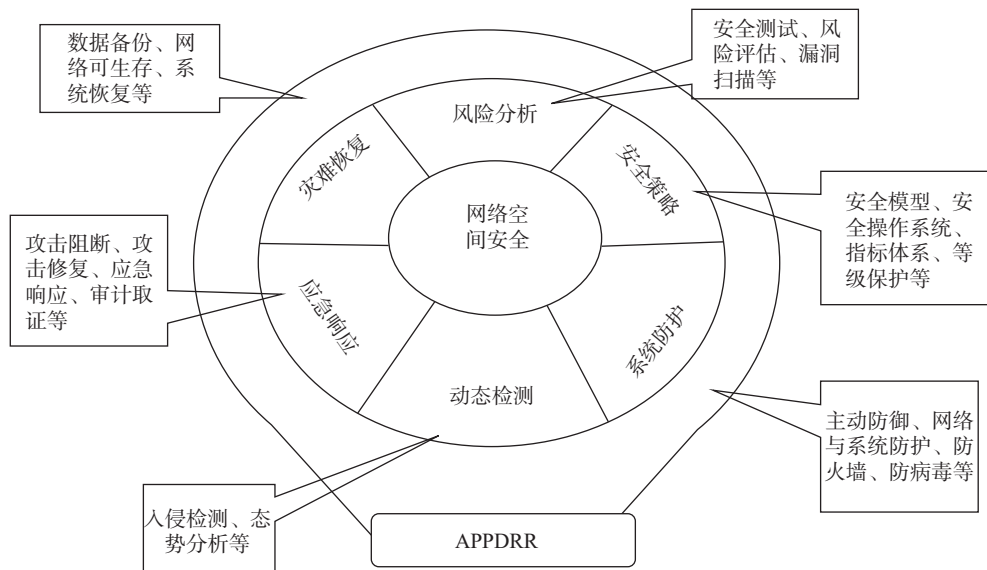


图1 APPDRR 模型

Fig. 1 APPDRR model

改善,其模型结构整体相对完善,有助于实现更加精细化的网络安全防护。

网络安全防御模型对网络安全的建设、管理及网络安全技术的发展起指导作用,但随着网络安全态势分析^[5]、主动防御^[6]、拟态防护^[7]等新兴网络安全防御技术的被提出与发展,APPDRR等模型已不适用于网络安全防御所面临的新场景。随着云计算、大数据和人工智能等技术的飞速发展,传统业务形态也发生了改变,其中人工智能领域中对抗样本攻击、区块链中的可验证延迟机制等内生安全手段^[5],使安全防御形式发生了显著的改变。网络安全态势感知等新的网络安全防御技术也为安全防御注入了新的血液。网络攻击技术特别是APT(Advanced Persistent Threat)攻击,主要使用未知攻击,使网络安全防御格局发生了改变。基于上述改变,网络安全防御的边界、技术和挑战等都发生了根本变化。传统网络安全防御框架各模块“各自为战”、相对静态的特点,使其无法应对APT攻击复杂、动态、各攻击阶段相互关联的问题。例如,APPDRR模型中的风险分析主要停留在与网络攻击运行态不相关的事先检测方面,而不是在攻击发生时的事中检测方面。现在的网络攻防是一个相互博弈、相互发展的过程,对网络空间防御模型有迭代更新的需求,但传统网络空间安全模型缺乏应对此变化的技术支撑。

分析APPDRR模型的基本要素——风险分析、安全策略、系统防护、动态检测、应急响应、灾难恢复,可以看出,这6个要素在实践中形成了必要的关联,而非静态存在。其中,动态检测、风险分析、应急响应是由安全保护者以解耦的方式为信息系统提供保护,同时动态检测可提升为感知(Sensing)检测,即在动态检测之外还可以通过网络欺骗来感知攻击者的存在;风险检测定位在发现了蛛丝马迹之后进行风险分析、风险检测,而非实现脱离攻防对抗过程的检测行为;应急响应则定位在将攻击者阻击在信息系统之外。为此,感知检测、风险分析(Assessment)和应急响应(Response)形成了“他人”保护的护卫模式。APPDRR模型的安全策略、系统防护、灾难恢复则是由信息系统所有者来实施,这便天然形成了“自我”保护的自卫模式。从该视角来看,APPDRR模型就被重构为SARPPR(Sensing-Assessment-Response-Policy-Protection-Restoration)模型。SARPPR模型将系统的“自我”保护和“他人”保护进行解耦,涵盖了防御技术的发展,如网络安全态势感知用于护卫模式,内生安

全用于自卫模式;SARPPR模型适用于分布式、云计算等架构,如护卫模式用于外置模式,自卫模式用于内置模式;SARPPR模型解耦不同系统的应用特性,如护卫模式应对网络安全问题的通用性,自卫模式强化内生安全的个性化特性。各模块相互联动的特性,使其可以应对APT攻击中的未知攻击检测。针对网络空间安全领域攻防博弈情况,本文还提出迭代模式(亦称近卫模式),其在知己知彼的对抗过程中不断迭代防御策略。

在SARPPR模型中,感知是基础,研判是核心,阻截是根本,自卫是底线。SARPPR模型支撑保障了北京冬奥会、杭州亚运会、成都大运会、第16—18届文博会、第127—135届广交会等重大活动的网络安全,实现了零事故,实践效果验证了该模型可以更好地应对网络安全威胁和风险,提高网络的安全性和稳定性,保障个人、企业和国家的利益。

1 相关工作

传统网络安全体系主要基于静态开环控制的保护,通过保护信息的机密性和完整性来抵御攻击。但该体系缺少足够的对安全威胁动态性、系统脆弱性的描述和应对措施。随着网络安全技术的不断发展,基于动态闭环控制的网络安全模型逐渐发展起来,Schwartz首先提出了PDR模型^[1],即保护—检测—响应。美国国家安全局制定的信息技术保障框架(Information Assurance Technoical Framework, IATF)将信息保护阶段由PDR的3个扩展为4个,加入了恢复阶段,发展形成了PDRR^[2]。美国国家标准与技术研究院进一步添加了识别(Identify)阶段,将PDRR扩展成为IPDRR^[3]。APPDRR^[4]将网络安全防御模型扩展为风险分析、安全策略、系统防护、动态检测、应急响应和灾难恢复,是目前应用最为广泛的网络安全防御模型之一,在互联网安全事件应急处理中发挥着重要作用。

传统的风险分析主要有安全测试^[8]、风险评估^[9]、漏洞扫描^[10]等,动态检测有入侵检测^[11-12]、态势分析^[13]等,应急响应有攻击阻断、攻击修复、应急响应、审计取证等,这3部分可以归结为“他人”保护;安全策略^[14]主要有安全模型、安全操作系统、指标体系、等级保护等,系统防护包含主动防御^[6]、网络与系统防护、防火墙^[15-16]、防病毒^[17]等,灾难恢复^[18]包含数据备份、网络可生存、系统恢复等,这3部分可以归纳为“自我”保护。网络安全防御模型作为技术发展的指导,以往忽视了“他人”保

护与“自我”保护的客观存在,使各安全技术要素相互孤立,最多也就是将动态检测与系统防护联系在一起,形成统一威胁管理模式^[19]。此种静态的应对方式已无法指导新技术的发展,也无法应对网络安全防御领域新的问题。

在“他人”保护中,随着 APT 攻击的发展,传统基于规则或异常检测的风险分析、动态检测都无法用于未知攻击的检测^[20]。随着靶场技术^[21]、网络安全态势感知技术^[22]、网络安全研判技术^[5]的发展,对 APT 未知攻击的检测是“他人”保护中各模块的联动,而传统网络模型如 APPDRR 无法表示这种联动关系。在“自我”保护中,由于云计算、分布式等架构的发展,网络的边界发生了变化,不同系统中应有不同的防御策略、防御手段、灾难恢复等。另外,拟态安全^[7]、可信计算^[23]等“自我”保护技术与“他人”保护的网络安全态势感知技术并行发展,完全可以并行推进、协同部署。因此,“护卫+自卫”的防御模式可以更好地涵盖新技术的发展,指导网络安全防御体系的建设和管理。

2 SARPPR 模型

APPDRR 模型中的 6 个安全要素可以看作是在事前、事中、事后 3 个阶段发挥作用。其中,事前阶段包含动态检测和安全策略,分别表示为他人负责的事前检测和为己方负责的事前部署;事中阶段包含风险分析和系统防护,分别表示为他人负责的事中研判和为己方负责的事中防御;事后阶段包含应急响应和灾难恢复,分别表示为他人负责的事后阻断和为己方负责的事后恢复。这 3 个阶段可以拆解为他人保护和自我保护两个部分,分别称之为“护卫模式”和“自卫模式”。

“护卫模式”由动态检测、风险分析和应急响应 3 个要素组成。防御方需要在攻击进入信息系统之前进行拦截。考虑到攻击者远离被防护系统,因此,被防护系统需要第三方护卫者对其进行保护。在事前检测阶段,需要护卫者进行感知、监测,以便发现攻击者是否存在;在事中研判阶段,当检测到攻击者时,需要护卫者进行检测、研判;在事后响应阶段,需要护卫者对攻击者做出反应,进行拦截。

“自卫模式”由安全策略、系统防护、灾难恢复 3 个要素组成。此时假定护卫者可能会出现漏防,需要被保护系统的自卫者进行自我保护。首先,自卫者需要采取适当的安全策略,最大限度地减少自

身的脆弱点及受攻击的暴露面;其次,自卫者自身需要具备抗击外部攻击的内生安全能力,以直面攻击者的入侵;最后,自卫者需要做好应对最坏情况的准备,如系统最终被攻陷、数据最终被破坏。因此,自卫者需要具备事后恢复的能力,以减小攻击对系统造成的损失。

综上,本文将经典的 APPDRR 模型重构为“护卫模式+自卫模式”的 SARPPR 模型。护卫模式即 SAR,包含感知检测、风险分析和应急响应;自卫模式即 PRR,包含安全策略、系统防护和灾难恢复。在“护卫模式+自卫模式”的 SARPPR 模型中,感知为基础,研判为核心,拦截是根本,自卫是底线。

2.1 护卫模式

护卫模式是以抗击为目的的主动防御模式,针对外敌进行外部统筹防御,以感知检测为基础,通过分析研判发现潜在攻击者,最终对攻击者进行拦截。护卫模式是一种与应用系统相解耦的防御模式,可视为外置安全防御,具有普适的保护能力。一般而言,护卫者的关注重点在于谁是攻击者,至于被护卫的信息系统有什么问题则不是护卫者所关心的,因为只有如此,才能做到保护的普适性。如图 2 所示,护卫模式通过在事前布陷探察,采用规则检测、异常发现、网络绊线、系统绊线等感知检测技术和手段构造网络诱骗环境,力求捕获有助于攻击研判的“蛛丝马迹”。在事中关联分析阶段,通过数据中台、态势感知、知识图谱和攻击判定将由各渠道所捕获的威胁情报统一汇聚起来,采用碰撞、关联、聚合等手段,以知识图谱等智能方法进行协同分析,旨在掌握威胁态势及攻击源头。在事后应急响应阶段,通过渗透清除、访问控制、边界防御和网络治理等手段,对攻击来源进行纵深式阻击拦截。

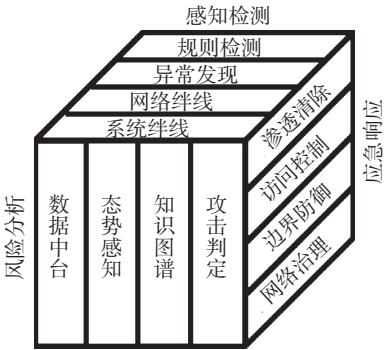


图 2 护卫模式结构
Fig. 2 Structural of guard mode

2.1.1 感知检测

攻击不可避免,护卫者聚焦于攻击痕迹的捕获,

采用规则检测、异常发现、绊线捕获等方法来构造网络诱骗环境，力求捕获有助于攻击研判的“蛛丝马迹”。

经典的 APPDRR 网络安全模型通过检测查看系统是否存在被入侵的现象。检测一般包括规则检测和异常检测两种手段，这两种手段都很重要，不可或缺，但都无法应对 APT 攻击。规则检测通过从已有攻击中提取规则对攻击进行匹配，对已知的攻击检测迅速，效率高，大部分网络攻击的发现都是依靠规则检测实现的。当然，此类攻击大多是由那些只会利用现有攻击工具来实施攻击的黑客发起的。但规则检测无法应对未知的 APT 攻击。为了应对未知攻击，人们同时采用了异常检测手段，以便发现那些不知道是否属于攻击但明显不属于正常操作的行为。在动态检测过程中经常出现大量的误报，它们大多来自异常检测。但是，异常检测仍然无法发现 APT 攻击，因为攻击者在发动 APT 攻击前，可以使用异常检测系统对自身的攻击进行检测判断，并不断更新迭代，直到现有的动态检测系统不报警之后才会实施攻击。为此，还需要采用网络欺骗技术来应对未知攻击，本文称之为“绊线”，此即“感知”的力量。SARPPR 模型的感知模块如图 3 所示。

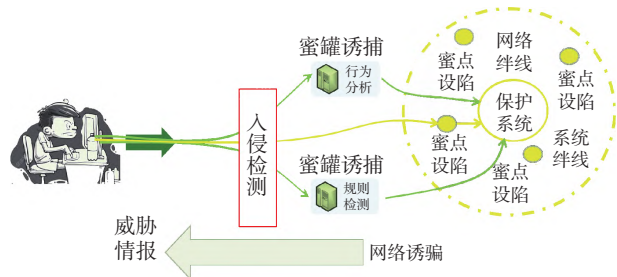


图 3 SARPPR 模型的感知模块

Fig. 3 Sensing module of SARPPR model

绊线的作用是为攻击者设置陷阱，一旦攻击者踏上了陷阱，就会被护卫者发现，甚至能够做到尽管攻击者还没有采取行动，护卫者也不知道攻击者的攻击手段是什么，攻击者仅仅是触碰到绊线，护卫者就能明确地知道谁是攻击者。当然，传统上人们习惯设置蜜罐^[24]来诱捕攻击者，但就实效而言，蜜罐的意义并不大。蜜罐的前提是鼓励各类访问，在对蜜罐的访问过程中，需要另外采取研判措施来判断访问者是否属于攻击者，这样便摆脱不了规则检测与异常检测的桎梏，从而解决不了规则检测与异常检测面临的问题。

网络绊线是在攻击者进行横向移动过程中所设

置的地址陷阱。对一些不对外提供服务的系统，例如 web 服务器背后的数据库系统，攻击者需要先通过横向移动来探索数据库的位置，然后再实施攻击。如果在数据库系统的周边（或逻辑周边）设置了足够的陷阱，由于内网中的访问通常是程序性行为，就算是用户直接访问也是按照一定的规则来进行，因此就不会触碰上述网络绊线。但攻击者则不同，其在横向移动探索的过程中注定要触碰上述网络绊线，因此，攻击者的身份就会因为这种盲目的探索而暴露无遗。当然在该过程中总会出现对抗性的博弈，例如攻击者通过探索来判断哪些是陷阱，哪些是活跃的工作节点。问题是护卫者也会如此思考，从而会模拟工作状态来发送相应的工作信息。正常用户不会访问上述绊线，这为绊线的诱捕提供了基本保证。

系统绊线是在对外公开的系统中所设置的诱饵陷阱。由于一些对外提供服务的系统已经是公开的，攻击者只需直接访问而无须以横向移动的方式进行探索。因此，网络绊线在这种情况下就失去了意义。需要在服务系统中设置系统绊线，例如设置一些看起来有用但实际上不会被访问的文件路径（超链接），设置一些看起来重要但实际上系统自身不会访问的文件，设置一些看起来可用但实际上从不分配出去的账号口令对，等等。此类设置也被称为面包屑的诱饵，由于不会被正常用户所触碰，因此任何试图触碰此类诱饵的访问者都会被认定为攻击者。

绊线的前提是正常用户不会触碰，因此触碰的一定是攻击者。由于攻击者不知道绊线的部署方式，防御者不知道攻击者的攻击方式，所以便形成了一种“以未知应对未知、以隐蔽应对隐蔽”的防御模式，此即采用绊线的方式可以有效应对 APT 攻击的逻辑所在。当然，在实践中安全扫描者、资源探测者也会触碰绊线，但对此类例外的甄别还是相对容易的。

2.1.2 风险分析

风险分析是基于感知阶段各个渠道所发现的攻击者的“蛛丝马迹”，并将相关的威胁情报汇聚起来，采用碰撞、关联、聚合等手段以知识图谱等智能方法进行协同分析，旨在掌握威胁态势及攻击源头。经典的 APPDRR 模型中的风险分析是静态的行为，没有时序方面的要求；SARPPR 模型中的风险分析则是在捕获信息后持续进行的迭代分析，具有时序的相关性。风险分析涉及数据中台、态势感知、知识图谱和攻击判定，如图 4 所示。

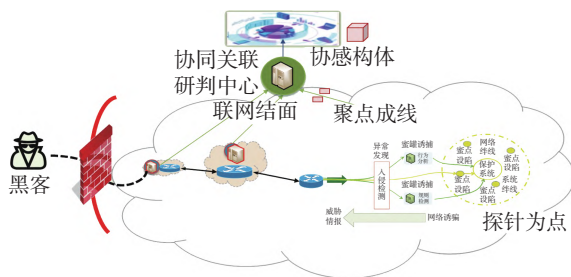


图4 SARPPR模型的风险分析模块

Fig. 4 Assessment module of SARPPR model

数据中台是指将感知到的各种情报汇聚到一个统一的数据平台上,从而可以对此类数据进行关联分析。在数据中台上,可以根据需要进行各种碰撞、关联分析。例如,同一个嫌疑IP还访问过哪些系统?同一种攻击行为还与哪些IP相关联?同一类系统都被哪些IP同时关注?一个因触碰过绊线而被认定为是攻击者的IP,都有哪些系统主动或被动地与其进行连接?等等。更为强大的数据中台还需要将所有的系统运行日志同步进来,这将有利于进一步分析一个触碰过绊线的攻击者在所访问过的系统中都进行了什么操作?在所访问的系统中都留下什么样的痕迹?甚至沉淀过什么样的信息?等等。

态势感知是指通过关联分析对威胁态势进行研判,从而达到感知威胁态势的目的。一种常见的方法是将各种威胁情报同时汇聚到同一个数据中台上,根据普遍性的威胁情报分析,对感知到的来自不同位置的信息进行碰撞,分析出当前的威胁态势,根据形势来判断应该以观察、跟踪、控制为主,还是以阻断、清除为主。更进一步,作者所在团队提出了“蜜场”的概念,目的是将确定的攻击者重定向到蜜场中,任其对蜜场中的孪生系统进行操作,以观察所面临的威胁程度,从而达到感知威胁态势的目的。

知识图谱是用于分析研判攻击方法与手段的重要工具。将各种已知的攻击、所利用的漏洞、被保护系统的资源状况等构建成一个庞大的网络安全知识图谱,目的是要准确研判攻击者的行为性质。就APT攻击而言,通常要经过多步攻击来达到其目的,而知识图谱将攻击的元操作、攻击之间的链接操作等纳入到分析体系中,使得仅试图通过手段的未知组合来躲避动态检测的攻击者,无法躲开基于知识图谱的风险分析。给APT攻击者带来的挑战是必须发明新的“元攻击”操作(不能再拆分为子攻击的攻击手段),而不能依靠基于已知“元攻击”操作

的组合来实施未知攻击。

攻击研判是最终确定谁是攻击者及采取什么手段进行攻击的重要环节。当然,由于知识图谱也属于规则,从一般性的道理来说,知识图谱对未知攻击也缺乏判断力。但在数据中台以及强大算力的保证下,可以将未知攻击分解为元攻击,只要元攻击是已知的,就可以通过模糊分析来进行攻击研判。例如,攻击者使用大量的不同IP进行迭代攻击,这让传统的防御者因不同的IP实施了不同的操作而不认为属于攻击,但攻击研判系统则将所有访问同一个被保护系统的IP视为同一个逻辑IP(或称之为IP簇),在此前提下进行知识图谱观察,绝大部分APT攻击逃避不了此种研判。对于元操作不在知识图谱中的情况,可以通过观察触碰了绊线而暴露了自己身份的攻击者的操作来发现新的元操作,从而及时更新知识图谱。例如,作者在保护广交会的过程中,通过此种方式发现了“上传乘法操作”这类看不出来是攻击的元操作,又通过绊线的方法锁定了此种用于唤醒木马病毒的基本操作。

2.1.3 应急响应

人们习惯于将网络安全防御神秘化,其实网络安全防御在本质上无非就是3件事:在没攻进来之前阻截攻击,此为防火墙所做之事;在攻击进来之后清除攻击代码,此为杀毒软件所做之事;在清除不了攻击代码的情况下,系统要像“不倒翁”一样打不垮,此为拟态防御需要完成的工作。

感知检测和风险分析的最终目的都是阻截攻击,不实施阻截攻击的任何态势感知与风险分析操作都应该看成是无意义的操作。因此,感知检测、风险分析与应急响应之间需要进行关联互动,这也是SAR“护卫模式”的核心要点。通过感知检测和风险分析捕捉到攻击之后,需要及时通知防御系统进行应急响应,响应方式包括渗透清除、访问控制、边界防御、网络治理,如图5所示。

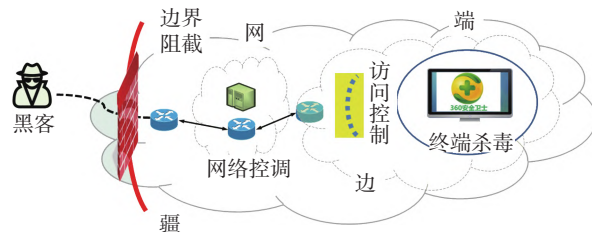


图5 SARPPR模型的应急响应模块

Fig. 5 Response module of SARPPR model

渗透清除是在通过绊线的方式感知到确定的攻

击者 IP 之后, 核查该 IP 此前都向哪些信息系统进行过渗透, 包括注册信息、使用缓存等, 然后立即从此类系统中将该 IP 所沉淀的所有代码及信息都清除, 即便此 IP 当时得到了合法授权, 甚至是以管理员身份进来也需要无条件清除。

访问控制的本质是一种白名单的管理模式, 即根据授权而实施放行机制的方式。当一个 IP 被风险分析定性为确定的攻击者后, 就需要审查该攻击者是否曾经通过了访问控制的防护, 如果是, 就需要审视什么原因使得该攻击者获得授权, 从而同步清洗必要的攻击沉淀, 取消其授权, 调整防御策略, 以防系统再受攻击。当然, 访问控制的模式并不限于 IP 白名单的放行机制, 还可以采用白操作(行为白名单)、白流量(载荷白名单)、白协议(互操作白名单)等确定安全条件的放行机制。零信任管理是访问控制的一个特例。

边界防御的本质是一种黑名单的管理模式, 即根据黑名单的情况进行直接封控, 只要是在黑名单中的 IP 就无法进入系统。同样, 边界防御的模式也并不限于 IP 黑名单的封禁机制, 还可以采用黑规则(行为黑名单)、黑流量(异常检测)、黑协议(限制类应用)等确定不安全条件的封禁机制。黑名单和白名单是两种不同的手段, 白名单是授权制, 被授权的人才能做, 黑名单是拦截制, 黑名单的人不能靠近系统。

网络治理利用网络传输过程的特性来应对攻击行为。例如, 在骨干网中, 运营商可以对 DDoS (Distributed Denial of Service) 之类的泛洪攻击进行清洗, 对某类协议进行统一的管理; 在局域网中, 可以通过网络结构变换来达到躲避、欺骗攻击者的目的。

2.2 自卫模式

自卫模式是以自保为目的的守护防御模式, 它通过安全策略构建安全基线, 通过防御系统保护系统安全, 通过灾难恢复守住安全底线。与经典的 AP-PDRR 模型中的系统防御不同, 自卫模式与护卫模式是联动的, 一些攻击的痕迹很有可能是护卫者无法发现的, 尤其对于那些原本对外提供信息服务的系统而言, 能在信息系统内部感知攻击者的可能性并不小。因此, 一旦自卫模式发现有攻击, 则需要立即溯源倒查攻击 IP, 并告知护卫者。一般而言, 自卫模式是在敌手进入后实施内生安全自保, 攻击者是谁不是重点, 唯有追求系统不被攻垮。自卫模式属于内生安全防御模式, 是一种利用应用系统自身

的能力来进行安全防御的模式。自卫模式的内生属性反映了安全与系统之间的紧密耦合。不同应用系统的内生安全防御模式不同, 人工智能分类系统反映在对抗样本攻击防御上, 移动通信反映在伪基站防范上, 区块链反映在可验证延迟函数的有效运用上。

如图 6 所示, 自卫模式在事前, 采用漏洞挖掘、基线检查和风险评估等方法来减少攻击面, 并借助护网演练发现新的安全漏洞及脆弱点, 力求提前消除隐患。在事中, 通过内生安全手段自行防御, 例如采用拟态防御、可信计算、入侵容忍等“以内生安全技术为主”的抵御攻击方法。在此, 防御模式并不关注攻击者是谁、在哪里, 但求系统自身不因攻击者钻空子而被控制甚至瘫痪。在事后, 采用系统冗余、数据备份、应用灾备等方法进行恢复, 以确保事后能够恢复系统及数据, 力争减少损失。

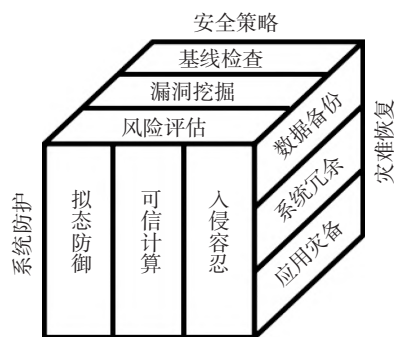


图 6 自卫模式的结构

Fig. 6 Structural of self-defense mode

2.2.1 安全策略

安全策略即事先制定安全基线、安全指标、等级保护、分级保护等管理策略以实施安全管理, 主要包括基线检查、漏洞挖掘和风险评估, 目的是要尽量降低系统的脆弱性, 减少系统的受攻击面。SARPPR 模型的安全策略设计如图 7 所示。

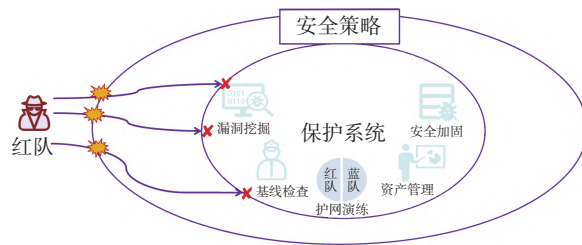


图 7 SARPPR 模型的安全策略设计

Fig. 7 Security strategy design for SARPPR model

基线检查在制订安全基线时, 要平衡安全强度与用户易用性的关系, 例如在确定密码的长度、密码的复杂性、密码的更换频率等方面, 需要平衡安

全的需要与易用性的要求。

漏洞挖掘是永恒的主题,旨在确保系统内尽可能少地存有漏洞。但随着新系统的不断上线,新的漏洞也会不断地出现,所以漏洞挖掘是一项持久的、没有终点的事情。

风险评估是强化安全管理的重要手段,旨在评估系统内部防御是否到位。安全扫描、护网演练、合规评测等就是要检查系统是否存在风险,是强化安全管理的必要手段。

2.2.2 系统防护

系统防护主要考虑的是系统不被击溃,而不在乎攻击者是谁,目的是要确保系统能够持续提供服务。目前,有多种安全防御措施可以选用,如拟态防御、可信计算、入侵容忍等。SARPPR模型的系统防护设计如图8所示。

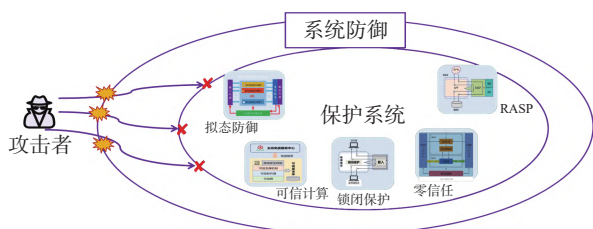


图8 SARPPR模型的系统防护设计

Fig. 8 System protection design for SARPPR model

拟态防御^[7]是多种不同的系统同时运行不同组件,当攻击者发动攻击时,系统或组件的差异性使得其中单一系统或组件的漏洞无法被激活,或者说就算被激活也无法通过多模表决此关。

可信计算^[23]是一种基于“白名单”或者说是“白操作”的安全保护体系,只要相应的应用或者操作未被事先认可,就不能通过授权运行此关,以确保未被授权的攻击者不能获得运行的机会。

入侵容忍是一种假定有攻击者入侵,但是只要攻击者不做坏事,系统就置之不理,一旦做坏事系统就出手的安全防御模式。例如,可以采取“锁闭保护”的防御模式,事先确定敏感操作并将之保护起来,攻击者只要不触动敏感操作,就算进入系统也可以安然无恙。一旦类似于写盘、注册表、外传等敏感操作被调用,则需要判断此敏感操作是否是预先部署的操作,而不是由恶意浮动代码所激活的操作,否则不予许可。由此可以确保系统运行的安全底线不被突破。

2.2.3 灾难恢复

灾难恢复建立在系统总会被攻破的假定之上,

而最后的底线是一定不能受到不可恢复的损失。为达成该目标,系统要具备各个层面的恢复能力,包括数据备份、系统冗余、应用灾备等。SARPPR模型的灾难恢复设计如图9所示。

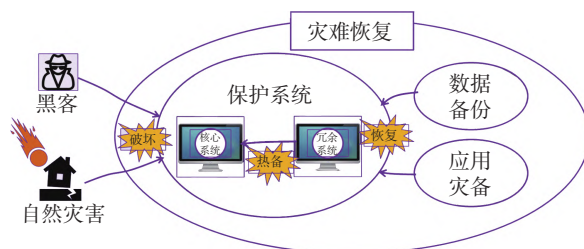


图9 SARPPR模型的灾难恢复设计

Fig. 9 Disaster recovery design for SARPPR model

数据备份的目的当然是为了数据恢复,勒索软件的致命之处就是假定受害者没有数据备份,从而通过对数据加密来勒索受害者。数据备份包括在线热备、离线热备、离线冷备等多种方式,其中在线热备必须考虑异构性,以防止系统被勒索攻击一网打尽。

系统冗余主要是防止系统被攻击致瘫,需要提前设计依靠冗余设备来接管运行正常业务。该技术原本是用了解决可靠性问题的,例如硬件容错、负载均衡等,但有效的冗余拓扑结构也可以应对致瘫性攻击,尤其异构冗余可以有效地应对勒索软件的技术性致瘫行为,因为同一种攻击很难让结构不同的系统同时瘫痪。

应用灾备采取异地、异构的冗余手段来确保系统的持续服务。同样,应用灾备的初衷也是应对可靠性问题,只不过应对的是大范围的灾难问题,如地震等。所以灾备强调的是异构性,两个系统不能使用相同品牌的机器,以防机器出现原生故障;不能使用相同的操作系统,以防出现相同的漏洞;不能使用相同的供电系统,以防供电系统存在相同的脆弱点;不能使用相同的网络运营商,以防运营商同时不提供服务;不能在同一个地质板块上,以防地震同时波及两个互备系统。例如,广交会应用系统就以“双活”的方式同时部署在南京和广州。

2.3 迭代模式

护卫模式的特点是不关注被保护系统的状态,自卫模式的特点是不关注攻击者是谁。显然,存在着一种中间状态:既需要知道敌人是谁,又要了解系统自身的状态,从而使得自身的防御体系可以随着对抗的不断演变而迭代调整,本文称此种模式为“迭代模式”。相对于护卫模式和自卫模式而言,

迭代模式也可以视为“近卫模式”，如图 10 所示。迭代模式主要涉及事前审计核查（Auditing），事中防御迭代（Iteration）和事后攻击测绘（Profile）3 个要素。

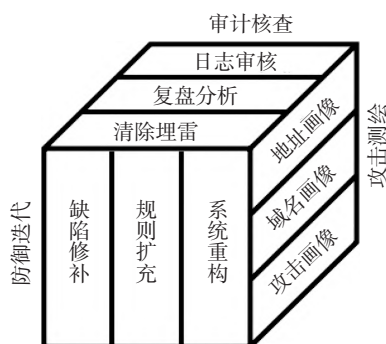


图 10 迭代模式的结构图

Fig. 10 Structural diagram of iterative mode

迭代模式属于近卫安全防御手段，是一种既关注系统运行状态又关注攻击者是谁的防御模式。迭代模式的核心是根据攻防对抗过程中所遗留或泄露的信息进行防御策略的调整，同时标注攻击者的画像，以便为今后的持续防御提供威胁情报。

2.3.1 审计核查

迭代模式在事前进行全面复盘审核，采用日志审核、复盘分析、清除埋雷等方法查找攻击者信息，并清除安全隐患。SARPPR 模型的审计核查设计如图 11 所示。

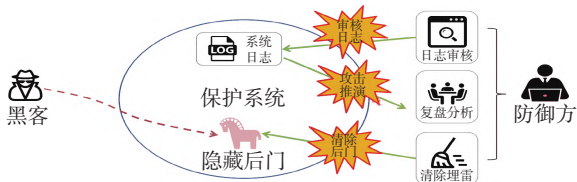


图 11 SARPPR 模型的审计核查设计

Fig. 11 Audit verification design for SARPPR model

日志审核是发现攻击者活动规律的最重要的手段，尤其是一个通过触碰绊线而被确认的攻击者对系统进行访问时，更需要通过日志审核来发现该攻击者的行为，甚至发现全新的攻击模式。

复盘分析是指在一次攻防博弈对抗之后需要进行的安全分析，无论是攻击成功还是攻击失败，都需要对攻击行为进行复盘演绎，以研判如何构建更直接有效的防御手段。

清除埋雷是日志审核的必然结果，在确定相关沉淀代码或者信息来自攻击者时，此类代码与信息就必须视为埋雷，需要立即清除。

2.3.2 防御迭代

通过审计核查获取系统存在的脆弱点后，需要用防御迭代将漏洞补上。在事中，需要通过缺陷修补、规则扩充、系统重构等方法来调整相应的防御策略，从而达到提升应对能力、进行防御迭代的目的，进而重建自身防御模式。SARPPR 模型的防御迭代设计如图 12 所示。



图 12 SARPPR 模型的防御迭代设计

Fig. 12 Defense iteration design for SARPPR model

缺陷修补主要是对在审计过程中发现的安全策略风险、安全漏洞、系统脆弱点等可能引发攻击者入侵的系统缺陷进行修补，当然常规性的操作也包括给系统打补丁等。

规则扩充主要是针对在审计过程中发现的攻击行为生成相应的防御规则，并加入到规则库中。例如，当发现一个因触碰绊线而被确认的攻击者多次向所访问的系统上传了“post 空”操作时，“post 空”操作就需要作为告警规则纳入到规则库中。

系统重构主要是在掌握了攻击者的行为规律、攻击路径、攻击跳板、渗透方式等相关行为特征后，通过系统重构进行后续的持续防御。

2.3.3 攻击测绘

攻击测绘在事后通过盘点攻击来源，基于发现的 IP 地址、域名、攻击代码等线索，采用地址画像、域名画像和攻击代码画像，发现更多威胁情报，从而更精准地对攻击者进行画像，进而充实威胁情报。SARPPR 模型的攻击测绘设计如图 13 所示。

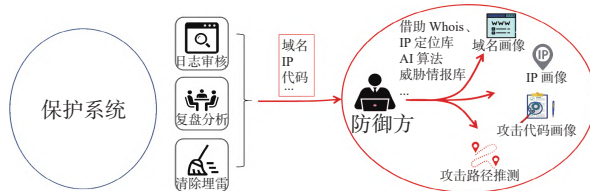


图 13 SARPPR 模型的攻击测绘设计

Fig. 13 Attack mapping design for SARPPR model

地址画像是指针对攻击者的 IP 地址进行攻击性的描述。网上有很多公开的 IP 测绘情报，但当发动 APT 攻击时，一般会选择数据库中“清白的、没有

案底”的 IP 发起攻击。因此，应该对那些因触碰红线而被锁定的 IP 进行非公开的地址画像。

域名画像是指攻击者在潜伏到受害者的系统中后，通过访问域名的方式对外进行勾连，需要将这些域名纳入到威胁情报中，一旦今后再次出现此类域名的访问，就需要进行必要的干预，以防止内外勾连而产生重大危害。

代码画像是指类似于勒索软件一样每发起一次攻击就会更换一个新的代码，但即便是代码发生了变换，攻击代码的家族特性仍然不会被抹掉，因此，记录攻击代码的家族特征有利于对新的攻击代码进行快速的分析报警。

2.4 3 种模式之间的关系

3 种模式之间的关系如表 1 所示。自卫模式对应着内生安全，其内涵为持枪自卫，用于用户自保，类比在水中的安全即学会游泳，自行渡河，其典型代表方法为拟态防御和可信计算；近卫（迭代）模式对应着内置安全，其内涵为贴身警卫，随动应对，类比在水中的安全即佩戴护具，安全渡河，其典型代表方法为杀毒软件和锁闭保护；护卫模式对应着外置安全，其内涵为军警护国，无关用户，类比在水中的安全即离开水面，乘船渡河，其典型代表方法为盾立方和安全托管。

表 1 3 种安全模式

Table 1 Three security modes

安全概念	内涵	类比在水中的安全	安全人员作用对比	安全模式	典型方法
内生安全	持枪自卫，用户自保	学会游泳，自行渡河	游泳教练	自卫模式	拟态防御，可信计算
内置安全	贴身警卫，随动应对	佩戴浮具，安全渡河	救生员	近卫模式	杀毒软件，锁闭保护
外置安全	军警护国，无关用户	离开水面，乘船渡河	救生船员	护卫模式	盾立方，安全托管

3 SARPPR 的应用

内生安全是由系统自身特点决定其安全防御模式，是一种自卫模式，它通常并不关心攻击者是谁，只关心如何不被攻垮，例如拟态防御和可信计算等；内置安全相当于安全系统进入应用系统内部进行攻击防范，但防御思路仍然是以判定谁是攻击者为主，是一种近卫模式，例如杀毒软件、锁闭保护安全系统等；外置安全则大包大揽，以解耦的方式保护信

息系统不受攻击者的攻击，是一种护卫模式，它重点关心攻击者是谁，例如 SASE 安全托管、盾立方安全防御体系等。要打造“护卫+自卫”的整体安全模式，护卫是最重要的，即 SAR 是最重要的，因此本节对一种被称为盾立方的护卫系统进行简单的介绍。

盾立方系统是基于网络安全态势智能感知关键技术 with 系统实现的，主要实现了网络安全大数据采集、超大规模网络安全知识图谱构建、网络安全事件发现、攻击溯源与场景还原、网络安全态势量化评估和网络安全态势预测。盾立方的感知手段来自被称为“四蜜”的（蜜点、蜜庭、蜜阵、蜜洞）网络欺骗方式，可以达到从各系统采集威胁数据的效果，所实现的网络安全大数据采集功能为后续风险分析提供数据支撑。为支撑风险分析，构建了超大规模网络安全知识图谱，从而实现网络安全事件发现、攻击溯源与场景还原、网络安全态势量化评估和网络安全态势预测。

盾立方系统的网络安全大数据实现日采集数量上亿条，支持终端病毒、网关、流量、服务日志、漏洞、情报等协同采集，采集的数据类型覆盖了攻击数据包、文件、服务、漏洞、攻击载荷、业务逻辑。应用在鹏城网络靶场，检测出未知网络攻击模式 92 个，实现了攻击溯源与场景还原，并在非协作网域空间进行实时追踪定位，能够追踪定位 5 跳及以下的攻击行为。可以对网络安全态势进行量化评估，实现了不同维度、不同粒度的网络安全态势量化分析。

在实际应用中，盾立方系统可以有效地对国家重大活动进行网络安全保障，如北京冬奥会、杭州亚运会、成都大运会和广交会等重大活动。

4 结束语

本文的研究目的是建立一种更加完善、灵活和高效的网络安全防御模型，以应对日益严峻的网络安全威胁。在已有的多种网络安全防御模型中，经典的 APPDRR 模型是最有影响力的安全模型之一。但随着网络安全态势分析、主动防御、拟态防护、盾立方等新兴网络安全防御技术的提出与发展，原来的网络空间安全防御模型已经不能满足网络安全技术的需求。本文将经典的 APPDRR 模型进行了重构，并在“关注攻击者是谁，还是关注防御者的能力”的基础上，首次提出了“护卫模式+自卫模式+迭代模式”的 SARPPR 模型，以涵盖和指导网络空

间安全防御的最新技术发展,促进了各模块之间的协同性和动态性。本模型为网络安全领域的进一步研究提供了新的思路和参考,并有望在实践中得到更广泛的应用。

参考文献:

- [1] SCHWARTAU W. Time-based security explained: provable security models and formulas for the practitioner and vendor[J]. Computers & Security, 1998, 17 (8): 693-714.
- [2] LI D, AUNG Z, WILLIAMS J, et al. P2DR: privacy-preserving demand response system in smart grids[C]//2014 International Conference on Computing, Networking and Communications (ICNC), 2014: 41-47.
- [3] ZHANG X, BHUYAN L N. Deficit round-robin scheduling for input-queued switches[J]. IEEE Journal on Selected Areas in Communications, 2003, 21 (4): 584-594.
- [4] DEBNATH B, DAS J C, DE D, et al. Security analysis with novel image masking based quantum-dot cellular automata information security model[J]. IEEE Access, 2020, 8: 117159-117172.
- [5] 贾焰, 方滨兴, 李爱平, 等. 基于人工智能的网络空间安全防御战略研究 [J]. 中国工程科学, 2021, 23 (3): 98-105.
JIA Y, FANG B X, LI A P, et al. Artificial intelligence enabled cyberspace security defense[J]. Chinese Journal of Engineering Science, 2021, 23 (3): 98-105.
- [6] SATCHIDANANDAN B, KUMAR P R. Dynamic watermarking: active defense of networked cyber-physical systems[J]. Proceedings of the IEEE, 2017, 105 (2): 219-240.
- [7] 郭江兴. 网络空间拟态防御研究 [J]. 信息安全学报, 2016, 1 (4): 1-10.
WU J X. Research on cyber mimic defense[J]. Journal of Cyber Security, 2016, 1 (4): 1-10.
- [8] GALLOWAY A R, THACKER E. The exploit: a theory of networks[M]. London: University of Minnesota Press, 2013.
- [9] AHMED M S, AL-SHAER E, KHAN L. A novel quantitative approach for measuring network security[C]//IEEE INFOCOM 2008-The 27th Conference on Computer Communications, 2008: 1957-1965.
- [10] KALS S, KIRDA E, KRUEGEL C, et al. SecuBat: a web vulnerability scanner[C]//Proceedings of the 15th International Conference on World Wide Web, 2006: 247-256.
- [11] DENNING D E. An intrusion-detection model[J]. IEEE Transactions on Software Engineering, 1987 (2): 222-232.
- [12] MUKHERJEE B, HEBERLEIN L T, LEVITT K N. Network intrusion detection[J]. IEEE Network, 1994, 8 (3): 26-41.
- [13] SHIRAVI H, SHIRAVI A, GHORBANI A A. A survey of visualization systems for network security[J]. IEEE Transactions on Visualization and Computer Graphics, 2011, 18 (8): 1313-1329.
- [14] MARIN G A. Network security basics[J]. IEEE Security & Privacy, 2005, 3 (6): 68-72.
- [15] IOANNIDIS S, KEROMYTIS A D, BELLOVIN S M, et al. Implementing a distributed firewall[C]//Proceedings of the 7th ACM Conference on Computer and Communications Security, 2000: 190-199.
- [16] NELSON T, BARRATT C, DOUGHERTY D J, et al. The margrave tool for firewall analysis[C]//Proceedings of the 24th International Conference on Large Installation System Administration, 2010: 1-8.
- [17] GRIMES R A. Malicious mobile code: virus protection for Windows[M]. California: O'Reilly Media, Inc., 2001.
- [18] DOSHI B T, DRAVIDA S, HARSHAVARDHANA P, et al. Optical network design and restoration[J]. Bell Labs Technical Journal, 1999, 4 (1): 58-84.
- [19] AGHAM V. Unified threat management[J]. International Research Journal of Engineering and Technology, 2016, 3 (4): 32-36.
- [20] MILAJERDI S M, GJOMEMO R, ESHETE B, et al. Holmes: real-time APT detection through correlation of suspicious information flows[C]//2019 IEEE Symposium on Security and Privacy (SP), 2019: 1137-1152.
- [21] 方滨兴, 贾焰, 李爱平, 等. 网络空间靶场技术研究 [J]. 信息安全学报, 2016, 1 (3): 1-9.
FANG B X, JIA Y, LI A P, et al. Cyber Ranges: state-of-the-art and research challenges[J]. Journal of Cyber Security, 2016, 1 (3): 1-9.
- [22] MILAJERDI S M, ESHETE B, GJOMEMO R, et al. POIROT: aligning attack behavior with kernel audit records for cyber threat hunting[C]//Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security, 2019: 1795-1812.
- [23] CHALLENGER D, YODER K, CATHERMAN R, et al. A practical guide to trusted computing[M]. London: Pearson Education, 2007.
- [24] PROVOS N. A virtual honeypot framework[C]//Proceedings of the 13th USENIX Conference on Security Symposium, 2004.